



Critical Infrastructure: Hacking and Forensics 关键基础设施的攻击和取证

K P Chow and Frankie Li¹

**Center for Information Security and Cryptography
University of Hong Kong**

香港大学资讯保安及密码学研究中心

¹Aka Ran2



The project is partially supported by the HKU
Knowledge Exchange Funding (Impact Project).



我们是谁？



- Ran2是专门从事计算机取证和恶意软件分析的独立研究人员。他目前的研究包括高级持续性威胁（APT）恶意软件归属和使用开源大数据识别可能的恶意敌手。他是SANS协会在香港开设的恶意软件和取证课程的导师，也是2014美国黑帽大会（Blackhat USA 2014）和2014台湾骇客年会（HITCON 2014）的发言人。Ran2获香港大学电子商务及互联网工程（ECom/IComp）硕士学位。
- 邹锦沛博士是香港大学计算机科学系副教授，同时也是香港大学资讯保安及密码学研究中心副主任。邹博士研究领域包括计算机取证，网络监控和隐私，他在本地和国际会议及期刊上发表了多篇关于计算机取证，数据安全和密码学的论文。在过去的几年中，邹博士数次被邀请作为计算机取证专家，协助香港法院判案。
- Other contributors: Ken Yau, Raymond Chan, Xiaoxi Fan, Yanbin Tang



Computer Forensics F

目录

- 什么是ICS (SCADA)系统和关键基础设施？
- 专有 (Proprietary) 是安全吗？
- SCADA攻击事件和SCADA攻击的概念验证 (POC)
- Stuxnet和Havex恶意软件攻击
- SCADA系统取证的挑战和研究





工业控制系统（ICS）



是几种控制系统的统称，包括：

- 数据采集与监视控制系统（SCADA）
- 分布控制系统（DCS）
- 其他控制系统如嵌入式设备或可编程逻辑控制器（Programmable Logic Controller PLC）

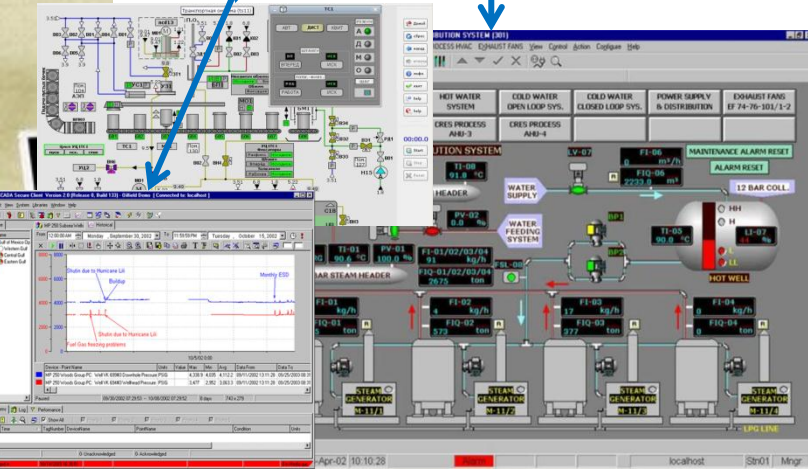
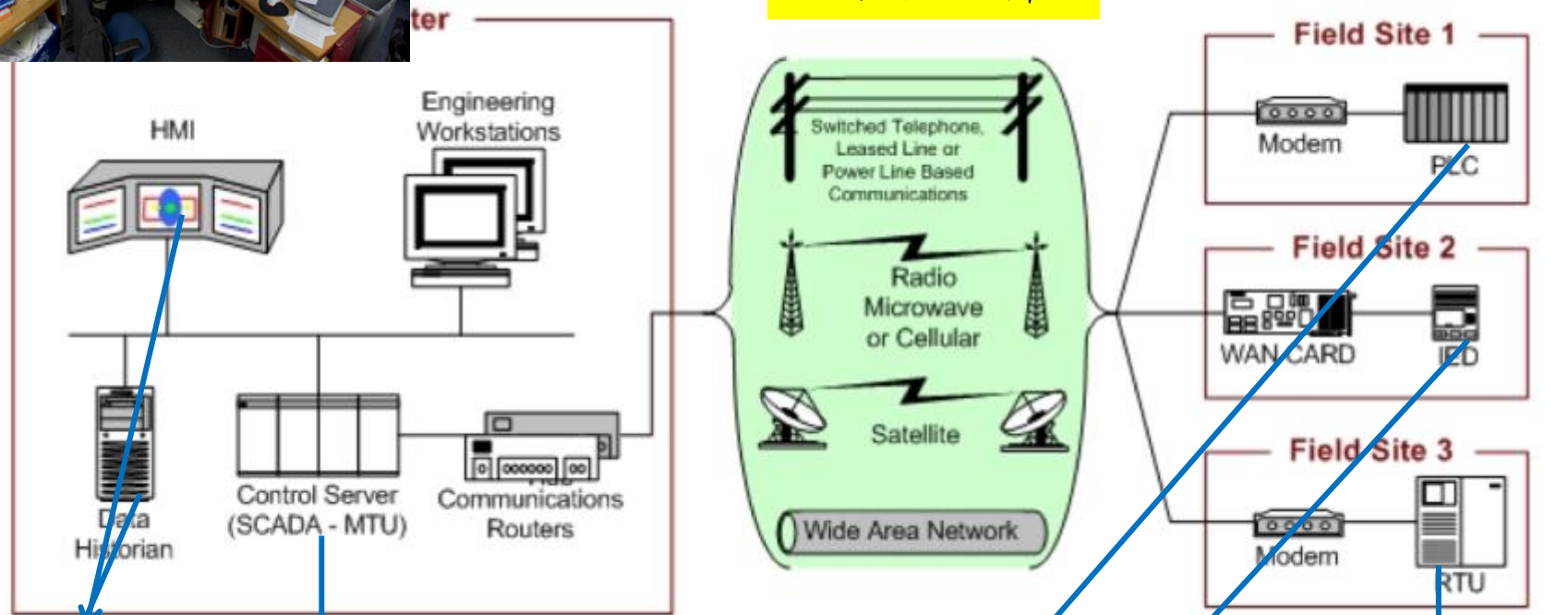


NIST SP 800-82: Guide to Industrial Control System (ICS) Security, May 2013



简单的SCADA

网络组件





The SCADA Components

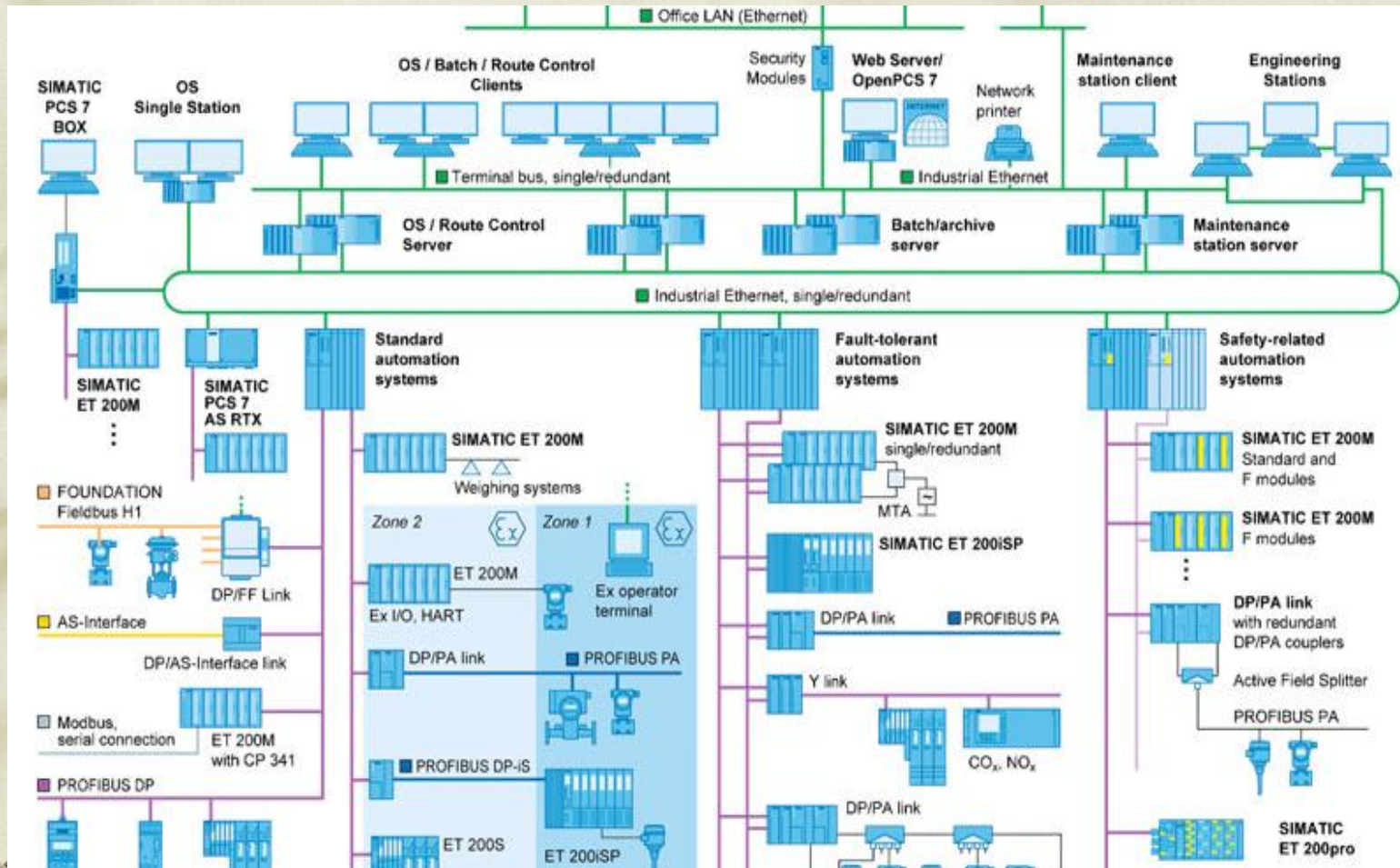
- Control Server
- SCADA Server or Master Terminal Unit (MTU)
- Remote Terminal Unit (RTU)
- Programmable Logic Controller (PLC)
- Intelligent Electronic Devices (IED)
- Human-Machine Interface (HMI)
- Data Historian
- Input/Output (I/O) Devices





Computer Forensics Research Group

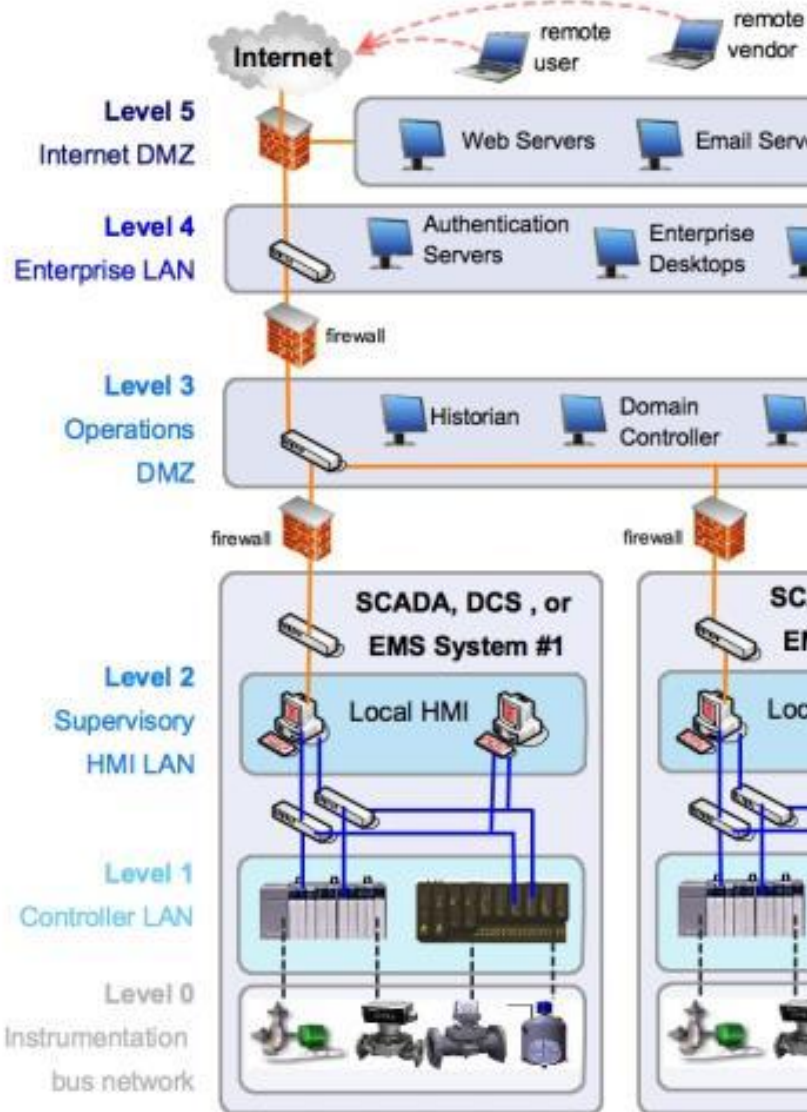
复杂的SCADA体系结构





控制系统安全模型

Industrial Firewalls and IDS/IPS



工控信息防火墙的创新点

1. 集中式工控信息防火墙在硬件上采用高速ASIC可编程网络芯片,能通过可编程的方式,下发ACL规则,达到防火墙控制数据报文的目的。与此同时,ASIC网络芯片的选用能确保工控数据的高速转发速度,对实时性要求较高的工控场合,能保障工控数据的更有效传输,并能高效处理传统IT防火墙中难以处理的FLOOD攻击问题。
2. 双端口的工控防火墙采用集中式防火墙同样的网络处理器芯片架构,由于拓扑结构简单,更加易于与工控环境集成,同时代码一次编写,完全可以复用,节省了开发开销,同时降低了技术风险。
3. 针对工业领域复杂的场合,支持区域规则组预设,简化了操作人员设置复杂协议规则的工作。
4. 工控信息防火墙通过统一的NMS管理接口,抽象了管理的概念,为一体化安全控制的网管提供了前提保障。

工控IDS/IPS主要功能参数

主要参数	
过滤技术防御能力	3200+, 可防御至少3200种过滤技术,并不断更新增加中
高级过滤技术防御能力	可防御3200+种过滤技术任意组合的高级过滤技术
保护	免受来自网络的对客户端和服务器的漏洞进行攻击的应用程序和操作系统
检测	缓存溢出错误、蠕虫、间谍软件、DoS/DDoS、后门病毒、木马、病毒、潜在攻击、可疑信息流、零日、P2P、DM、流式播放协议
网页过滤	根据网页过滤解决方案进行分类,在77个类别中包含几百万URL,用于确保精确的可见性和对网页浏览的控制性,附加许可证选项。
检测库数量	3300+



Computer Forensics Research Group

谁使用SCADA?

- ICS (SCADA)系统用于多种工业如电力、水资源与废水处理、石油与天然气、化工、交通运输、医药、造纸、食品与饮料、以及离散制造（如汽车和航空）
- 以上一些ICS被列为**关键基础设施**，因为任何中断都可能导致对国家灾难性的影响或严重的经济/社会后果（或生命损失）





Computer Forensics



美国关键基础设施

- 农业与食品系统
- 银行与金融系统
- 化工产业
- 商业设施
- 关键工业设施
- 水坝
- 国防工业基础
- 紧急救护服务
- 能源供应系统
- 政府运转体系
- 信息技术系统

- 国家级象徵物
- 核能反应、材料、废弃物系统
- 邮政船务
- 公共医疗系统
- 通讯系统
- 运输系统
- 水资源与水处理系统

Homeland Security Presidential Directive 7 (HSPD-7) categorized U.S. critical infrastructure into the above sectors. Many of the processes controlled by computerized control systems that they can no longer be operated without the control system.



专有是安全吗？

Proprietary is Security?



Frankie Li
@Espionageware

Follow

“@Espionageware: Hong Kong Government believed our signalling system is free from attack” I am pissed. #scada
pic.twitter.com/7mVOnglGi1

Reply Retweet Favorite More

The signalling system of various railway lines (including) is an independent system. It is believed that outside parties are unable to enter the system to launch an attack. In fact, conducts risk assessment on the security of the signalling system from time to time and formulates corresponding measures to prevent malicious attacks.

has engaged an independent expert to carry out comprehensive analysis and assessment on the signalling system of and make recommendations for improvement. Furthermore, has engaged an independent consultant to evaluate the protection of the interface between the data network transmission and the signalling system.





通过隐藏实现安全性

Security Through Obscurity



- 在过去，SCADA系统使用专用设备或网络组件来实现
- 当SCADA通过WAN（如无线）和LAN（如以太网）连接到互联网后问题来了
- 因为“攻击者无法进入系统发动攻击”而认为ICS是安全的，这种理解是不正确的，因为动机、意图和资源是可被对手利用来制造**针对关键基础设施的高技术攻击（APT）**
- 通过隐藏实现安全性是不能防止恶意攻击的，反而可能导致理论上或实际的安全漏洞



SCADA系统已不再是隔离的



SCADA攻击事件之谜



- 在过去，SCADA是工程，而非IT系统
- 当今，SCADA攻击**并不**少见，如
 - 由有意或无意的行为造成的无法预料的负面事件与数字控制系统故障有关，会导致操作故障
- 过去几年：报告是必需的，但并没有适当地揭露原因，导致“SCADA攻击谬见”





一些SCADA攻击事件

A Short Chronological List of Widely Reported Incidents of Hacking and Disruption

- A February 2009 - The highly evasive Conficker/Downadup worm infects 12-15 million computers, creating botnets and stealing information. - BBC
- B June 2008 - "SCADA buffer overflow flaw revealed" - "Security Hole Exposes Utilities to Internet Attack" - Associated Press
- C May 2008 - "SCADA vulnerability discovered...control software package used by as many as one-third of the world's industrial plants." - SC Magazine
- D March 2008 - The Hatch nuclear plant in Georgia is forced into an emergency shutdown for 2 days as a result of a software update on a single business computer.
- E February 2008 - Retailed Chinese digital picture frames contain a virus that: blocks security, replicates, steals passwords and financial information. - SF Chronicle
- F January 2008 - "Hackers literally turn out the lights in multiple cities after breaking into electrical utilities and demanding extortion payments." - Associated Press
- G September 2007 - Homeland Security reveals the DOE Idaho National Engineering Lab video showing a remote destruction of a large SCADA controlled generator.
- H September 2007 - Hackers compromised dozens of Department of Homeland Security computers, moving sensitive information to Chinese websites. - CNN
- I July 2007 - 3Com's security division, Tipping Point, demonstrates how a SCADA system flaw can be exploited to cause a system crash.
- J November 2007 - "Insider Charged with Hacking California Canal System" - ComputerWorld
- K November 2007 - "Solar Sunrise" - Three teenagers penetrate US Air Force logistic systems at various Middle East support bases.
- L August 2007 - "Hackers Take Down the Most Wired Country in Europe" for a period of two weeks. - Wired Magazine
- M June 2006 - LiveData flaw - "Information on these (SCADA) systems can be found by a determined attacker." - US-CERT (Computer Emergency Readiness Team)
- N January 2006 - "A panel of public utility executives speaking at the Homeland Security for Networked Industries Conference agreed that remote monitoring and control systems, particularly SCADA systems, are vulnerable to intrusion attacks and should be protected more vigilantly." - UrgentComm
- O January 2006 - "SCADA Security & Terrorism: We're Not Crying Wolf" presentation to the Black Hat Federal 2006 Conference by Xforce Internet Security Systems.
- P August 2005 - 175 companies including Caterpillar, General Electric, UPS attacked by Zotob worm. DaimlerChrysler idles 50,000 workers at 13 US assembly plants.
- Q 2003-2005 - "Titan Rain" - US Department of Defense, Department of Energy and corporate networks are penetrated by Chinese People's Liberation Army, downloading 10-20 terabytes of data from the Pentagon's network. The hacking went undetected for two years.
- R August 2003 - CSX Railroad loses signaling, dispatch and other control systems throughout their 23 state rail network due to a worm virus. - InformationWeek
- S 2003 - "Cyber War" - PBS Frontline interview at Sandia National Labs reports their Red Team never fails to penetrate US utilities using common public methods.
- T January 2003 - Ohio Davis-Besse nuclear plant safety monitoring system knocked offline for 5-hours due to the Slammer worm.
- U January 2003 - "Slammer" worm infects 300,000 computers in the first 15 minutes, interrupting 911, ATM machines and airline reservation systems. Frontline
- V September 2001 - "Nimda" worm infects millions of computers causing billions of dollars in damage. The originator of the worm is still unknown. - Frontline
- W July 2001 - "Code Red" worm infects 300,000 computers in a month and then launches a simultaneous botnet attack on a White House web server. - Frontline
- X April 2000 - The Russian government announces that hackers succeeded in gaining control of the world's largest natural gas pipeline network (GAZPROM).
- Y April 2000 - Capture of hacker who used an Australian SCADA system to dump millions of gallons of sewage into hotel grounds for 3 months beginning in January.
- Z 1998-2000 - "Moonlight Maze" - For two years, hackers had penetrated the Pentagon, NASA, the Energy Department, private universities and research labs.
- AA 1998 - A 12-year-old hacked into Arizona's Roosevelt Dam. Federal authorities said he had complete SCADA system control of the dam's massive floodgates.
- BB 1997 - "Eligible Receiver" - An exercise uses publicly available hack methods to break into the Defense Department & Joint Chief Command system in 48 hours.
- CC 1997 - A teenager hacks into NYNEX and cuts off air and ground communication to Worcester Airport (Massachusetts) for 6 hours.

Many more incidents go unreported for reasons of national security or corporate embarrassment. Even more go undetected. Properly executed, successful hacks are undetectable and untraceable.





Computer Forensics Research Group

DaimlerChrysler (2005)

事件：2005年8月，互联网蠕虫感染了DaimlerChrysler的系统

影响：因为微软Windows系统打补丁导致工人停工

详情：一连串互联网蠕虫感染了DaimlerChrysler美国13个线下汽车制造工厂





Browns Ferry 核能电厂 (2006)



事件: 2006年8月, 核电厂3号机组的两个循环泵出现故障

影响: 该机组必须手动关闭

详情: 泵故障被曝由于控制系统网络上的流量过多, 可能是由另一个控制系统设备的故障引起的





Computer Forensics Research
CFRG

意大利交通灯 (2009)

事件：2009年2月，意大利当局调查未经授权更改交通系统事件

影响：两月内多出超过1400张罚单>25万欧元

详情：工程师被控与地方当局操纵交通灯，缩短黄灯时间导致相机执行交通罚单





Computer Forensics Research Group

SCADA 在线上? Shodanhq.com

SHODAN - Computer Search Engine

Shodan Exploits Scanhub Maps Blog Anniversary Promotion Register Login

SHODAN Search

PLC-5
PLC-5 EtherNet

EXPOSE ONLINE DEVICES.

WEBCAMS. ROUTERS.
POWER PLANTS. IPHONES. WIND TURBINES.
REFRIGERATORS. VOIP PHONES.

[TAKE A TOUR](#) [FREE SIGN UP](#)

Popular Search Queries: Anonymous access granted - title says it all, mostly FTP servers would be visible

DEVELOPER API

Find out how to access the Shodan database with Python, Perl or Ruby.

LEARN MORE

Get more out of your searches and find the information you need.

FOLLOW ME

Contact me and stay up to date with the latest features of Shodan.

IN THE PRESS

Shodan pinpoints shoddy industrial controls.

It greatly lowers the technical bar needed to canvas the Internet...

'Shodan for Penetration Testers' presented at DEF CON 18

It's a reminder to many to know what's on your network...

Shodan is the Google for hackers.

Shodan vereinfacht die Suche nach SCADA-Systeme erheblich...

Firmen öffnen Stuxnet und Co. selbst die Tür.

Computerangriffe werden einfacher. Zumindest für die Nutzer von Shodan.





SCADA连接到互联网

Computer Forensics Research Group

CFRG

SHODAN - Computer Search Engine

www.shodanhq.com/search?q=PLC-5+country%3ACN

Reader

Services

None

12

Top Cities

Hebei

Nanjing

Jinhua

Shenyang

Lishui

3

2

2

1

1

120.198.126.237

China Mobile

Added on 23.11.2013

Details

HTTP/1.0 200 OK

Content-type: text/html

Server: uc-httpd 1.0.0

Expires: 0

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">

<html xmlns="http://www.w3.org/1999/xhtml">

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<link rel="stylesheet" type="text/css" media="screen" href="m.css" />

<title>NETSsurveillance WEB</title>

<!-- m.js -->

<script type="text/javascript">

58.23.16.114

Xiamen city, fujian provincial network of CNCGROUP

Added on 22.11.2013

Fuzhou

Details

HTTP/1.0 200 OK

Date: Thu, 02 Dec 2010 15:05:55 UTC

Content-Type: text/html

Content-Length: 59612

Connection: Close

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">

<html>

<head>

<meta http-equiv="Content-Type" content="text/html; charset=UTF-8" />

<script type="text/javascript" src="m.js"></script>

<script type="text/javascript" src="m.js"></script>

<script type="text/javascript" src="m.js"></script>

<script type="text/javascript" src="m.js"></script>

<script type="text/javascript" src="m.js"></script>

110.243.241.194

China Unicom Hebei

Added on 11.11.2013

Hebei

Details

HTTP/1.0 200 OK

Content-type: text/html

Server: uc-httpd 1.0.0

Expires: 0

<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Transitional//EN" "http://www.w3.org/TR/xhtml1/DTD/xhtml1-transitional.dtd">

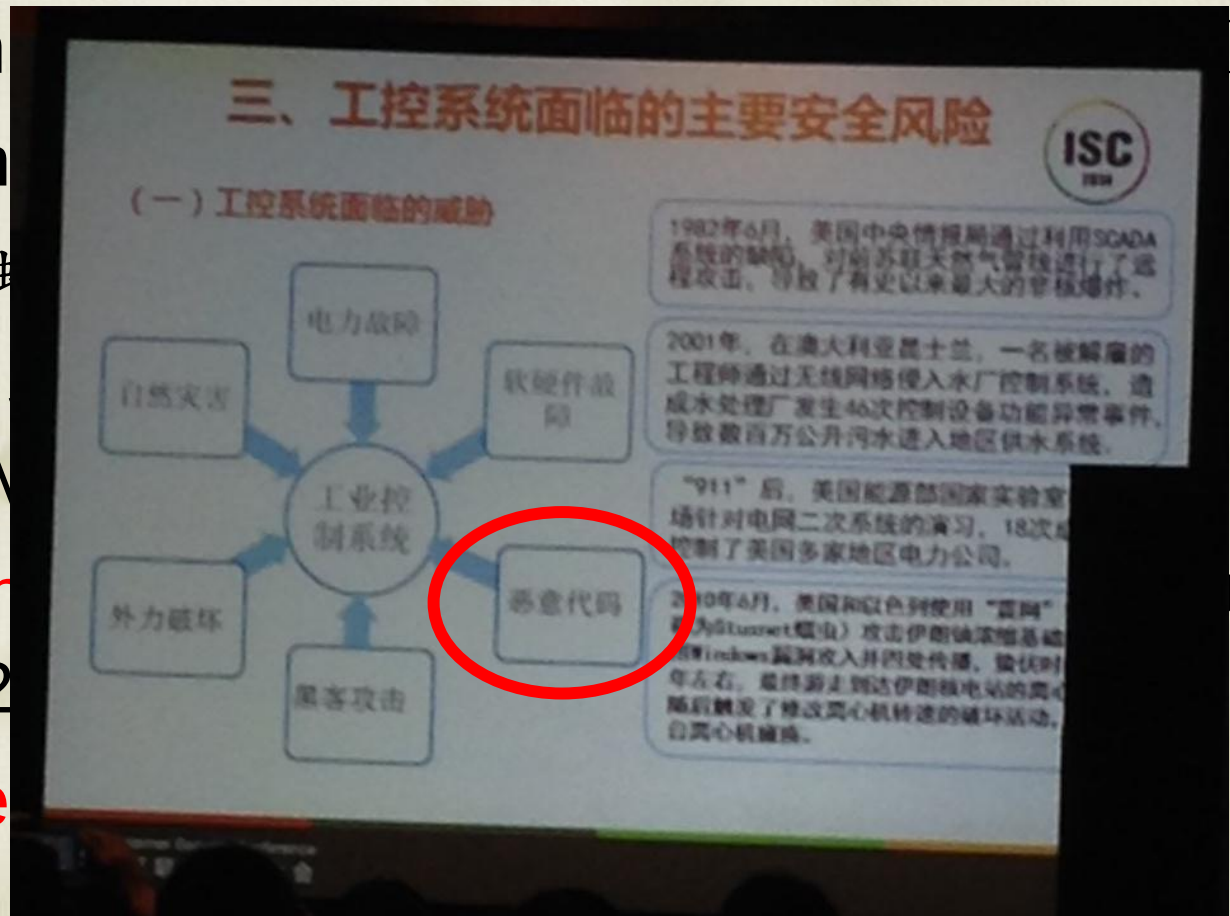
Hurricane LABS

SHODAN Maps



针对SCADA系统的恶意软件攻击

- Slam
- Nach
- 多种蠕虫
- SQL
- \$1.2M
- Stuxnet (6/2)
- Have



<http://www.f-secure.com/weblog/archives/00002718.html>





Computer

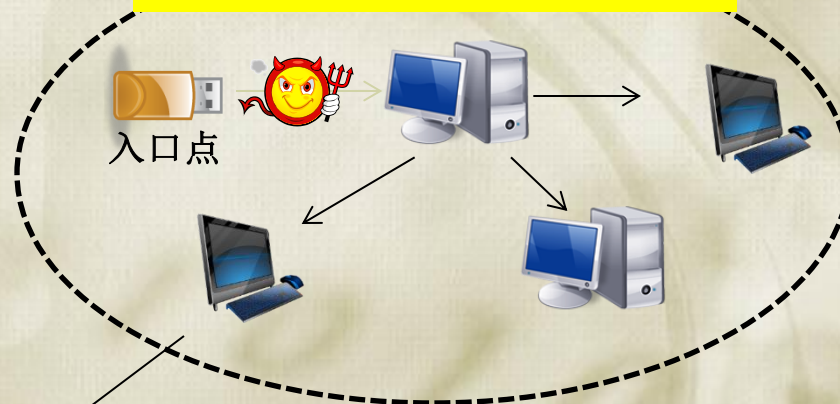


Stuxnet

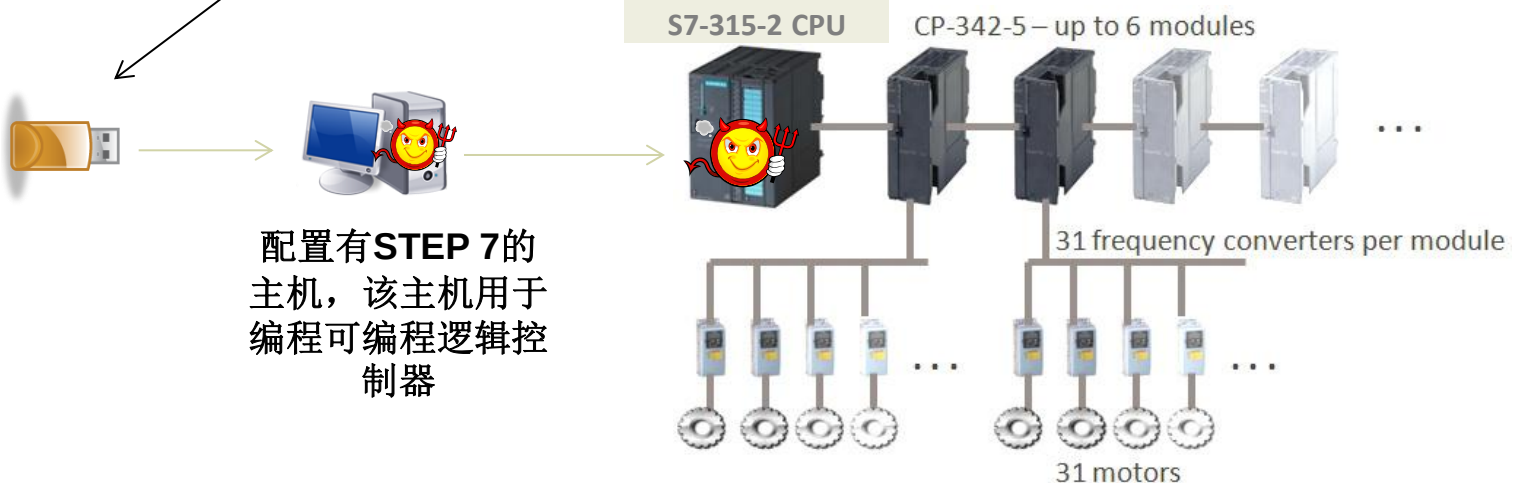
- 2010年6月，发现ICS蠕虫/病毒
- Myrtus + mrxnet.sys = Stuxnet
 - Myrtus: Stuxnet代码中的一个文件，希伯来语中 Esther 的一个典故
 - Mrxnet.sys: 在Stuxnet代码中的一个隐藏驱动程序
- 攻击源：可移动的U盘，以及客户端0-day漏洞
- 高度专业化的有效载荷，通过安装一个**无法检测**的PLC root kit，并且只针对西门子**PCS 7 PLC, STEP7**及WinCC应用
 - 受感染的PLC不会出现报警等异常行为

Stuxnet's 蠕虫感染方式的概述

Windows操作系统



西门子SCADA系统





Computer Forensics



Havex

- 针对不同行业有针对性的攻击，并特别对能源领域感兴趣
- 主要结构：一个通用的远程访问木马（ Remote Access Trojan RAT）和一个PHP编写的服务器
- 传播方式：侵入网站，并且更换客户可下载安装的合法安装软件
- 负载：ICS/SCADA网络监听





Havex 反汇编代码 (网络监听行为)

Computer Forensics Research
CF
RC

```
eax, [esp+98h+var_78]
esp, 0Ch
edi                ; dwCoInit
edi                ; pvReserved
[esp+94h+pServerInfo.pwszName], eax
[esp+94h+pResults.pIID], offset gIOPCServerList2 ; {9dd0b56c-ad9e-43ee-8305-487f
[esp+94h+pResults.pItf], edi
[esp+94h+pResults.hr], edi
ds:CoInitializeEx
eax, [esp+8Ch+pResults]
eax                ; pResults
ebx, ebx
ebx
ebx                ; dwCount
eax, [esp+94h+pServerInfo]
eax                ; pServerInfo
17h                ; dwClsCtx
edi                ; punkOuter
offset gIOPCServerList ; {13486D51-4821-11D2-A494-3CB306C10000}
[esp+0A4h+var_4], edi
ds:CoCreateInstanceEx
```

为了能够实现ICS/SCADA网络监听，连接至IID_IOPCServerList2服务，该服务是为实现过程控制的对象连接与嵌入



Metasploit 框架



- Metasploit 17个攻击模块
- Canvas 53个攻击模块
 - Gleg Agora SCADA+ Immunity CANVAS 开发包
 - 2个ICS供应商已经购买了CANVAS模块
 - Canvas的价格是US\$8,930





Computer Forensics Research Group

SCADA - POC Modules

Vendor	System / Component	SCADAhacker Reference	Metasploit Reference	Disclosure Date	Initial MSF Release Date
7-Technologies	IGSS	ICS-11-080-03	exploit/windows/scada/igss9_igssdataserver_install.rb	Mar. 24, 2011	May 16, 2011
		ICSA-11-132-01A	exploit/windows/scada/igss9_igssdataserver_rename.rb	Mar. 24, 2011	Jun. 9, 2011
			exploit/windows/scada/igss9_misc.rb	Mar. 24, 2011	May 30, 2011
			auxiliary/admin/scada/igss_exec_17.rb	Mar. 21, 2011	Mar. 22, 2011
AzeoTech	DAQ Factory	Click Here	exploit/windows/scada/daq_factory_bof.rb	Sep. 13, 2011	Sep. 17, 2011
3S	CoDeSys	Click Here	exploit/windows/scada/codesys_web_server.rb	Dec. 2, 2011	Dec 13, 2011
BACnet	OPC Client	ICSA-10-284-01	exploit/windows/fileformat/bacnet_csv.rb	Sep. 16, 2010	Nov. 11, 2010
	Operator Workstation	n/a	exploit/windows/browser/teechart_pro.rb	Aug. 11, 2011	Aug. 11, 2011
Beckhoff	TwinCat	Click Here	auxiliary/dos/scada/beckhoff_twinCAT.rb	Sep. 13, 2011	Oct. 10, 2011
General Electric	D20 PLC	Press Release	auxiliary/gather/d20pass.rb	Jan. 19, 2012	Jan. 19, 2012
		DigitalBond S4	unstable-modules/auxiliary/d20tftpbd.rb	Jan. 19, 2012	Jan. 19, 2012
Iconics	Genesis32	ICS-11-080-02	exploit/windows/scada/iconics_genbroker.rb	Mar. 21, 2011	Jul. 17, 2011
			exploit/windows/scada/iconics_webhmi_setactivexguid.rb	May 5, 2011	May 11, 2011
Measuresoft	ScadaPro	Click Here	exploit/windows/scada/scadapro_cmdexe.rb	Sep. 16, 2011	Sep. 16, 2011
Moxa	Device Manager	ICS-10-293-02 ICSA-10-301-01	exploit/windows/scada/moxa_mdmttool.rb	Oct. 20, 2010	Nov. 6, 2010
RealFlex	RealWin SCADA		exploit/windows/scada/realwin.rb	Sep. 26, 2008	Sep. 30, 2008
		ICS-11-305-01	exploit/windows/scada/realwin_scpc_initialize.rb	Oct. 15, 2010	Oct. 18, 2010
		ICSA-11-313-01	exploit/windows/scada/realwin_scpc_initialize_r.rb	Oct. 15, 2010	Oct. 18, 2010
			exploit/windows/scada/realwin_scpc_txevent.rb	Nov. 18, 2010	Nov. 24, 2010
		ICS-11-080-04 ICSA-11-110-01	exploit/windows/scada/realwin_on_fc_binfile_a.rb exploit/windows/scada/realwin_on_fc_login.rb	Mar. 21, 2011 Mar. 21, 2011	Jun. 19, 2011 Jun. 22, 2011
Scadatec	Procyon	Click Here	exploit/windows/scada/procyon_core_server.rb	Sep. 8, 2011	Sep. 12, 2011
ScadaTEC	ModbusTagServer ScadaPhone	Click Here	exploit/windows/fileformat/scadaphone_zip.rb	Sep. 12, 2011	Sep. 13, 2011
Schneider Electric	CitectSCADA		exploit/windows/scada/citect_scada_odbc.rb	Jun. 11, 2008	Nov. 8, 2010
	CitectFacilities				
Sielco Sistemi	Winlog	ICSA-11-017-02	exploit/windows/scada/winlog_runtime.rb	Jan. 13, 2011	Jun. 21, 2011
Siemens Technomatix	FactoryLink	ICS-11-080-01	exploit/windows/scada/factorylink_cssservice.rb	Mar. 25, 2011	Jun. 24, 2011
		ICSA-11-091-01	exploit/windows/scada/factorylink_vm_09.rb	Mar. 21, 2011	Jun. 21, 2011
Unitronics	OPC Server	n/a	exploit/exploits/windows/browser/teechart_pro.rb	Aug. 11, 2011	Aug. 11, 2011

Metasploit Modules (Privately Developed and/or Publicly Shared)

Vendor / Developer	System / Component	SCADAhacker Reference	Metasploit Module	Author	Date
DigitalBond	Schneider Modicon Quantum Credential Disclosure	pending	modiconpass	DigitalBond	Feb 14, 12
DigitalBond	Rockwell Automation ControlLogix Ethernet/IP	pending	ethernetip-multi	DigitalBond	Feb 14, 12
DigitalBond	Koyo/DirectLOGIC ECOM BruteForce	pending	koyobrute	DigitalBond	Feb 14, 12
SecureState	Nmap-like Meterpreter Extension (MSFMap 0.1.0)	n/a	msfmap	Spencer McIntyre	Dec 30, 11





Computer Forensics Research

SCADA系统取证的挑战

- 目前，对SCADA的取证方法都仅仅停留在概念层面
- **PLC**是一个简单的处理设备，它的操作系统（固件）是经过特殊的设计，并且功能非常有限：**没有工具**可以像侦测到Stuxnet蠕虫那样检测到PLC rootkit
 - **PLC内部**：无内置日志、无额外存储空间, 用于存储警报或取证信息的内外部存储器
- 取证项目可能在历史数据库中存在
- 假如HMI或控制服务器是安装在一个Windows操作系统中，传统的Windows取证操作可能有助于相应攻击的检测

我们的观点：实时网络取证可以帮助取证分析，但对SCADA系统进行现场取证有可能会威胁到系统的正常运行



Computer Forensics Research Group

SCADA系统的事件响应是如何的？

- PLC需要24小时持续运作，通常不能为了调查而将其停止
- 许多远程处理单元
- 系统设计及工程师缺乏信息安全方面的相关知识
- 未知的嵌入式/专有的操作系统
- 缺乏网络安全方面的相关知识
- ...





近来的研究(2014)

- Programmable Logic Controller Modification Attacks, Air Force Institute of Technology, IFIP WG 11.10 Conference on CIP, Mar 2014
- Green Lights Forever: Analyzing the Security of Traffic Infrastructure, USENIX, Aug 2014
- Blackhat Aug 2014: demo units available
- Accurate Modeling of the Siemens S7 SCADA Protocol for Intrusion Detection and Digital Forensics, Tel Aviv University, ICDF2C, Sep 2014
- The SCADA That Didn't Cry Wolf, Who's Really Attacking Your ICS Equipment? TrendMicro, 2014

- 在美国，PLC上的关键基础设施攻击和恶意软件攻击是主要的研究领域之一



我们的研究

- 关键基础设施事件模拟器 **CRISIS – Critical Infrastructure Incident Simulator**

- 一个关键基础设施的模拟器，是用于关键基础设施网络攻击演习演练的平台
- 研究关键基础设施关键组件。例如：可编程逻辑控制器 PLC，在被恶意软件攻击时的行为



西门子Simatic PLC S7-1200

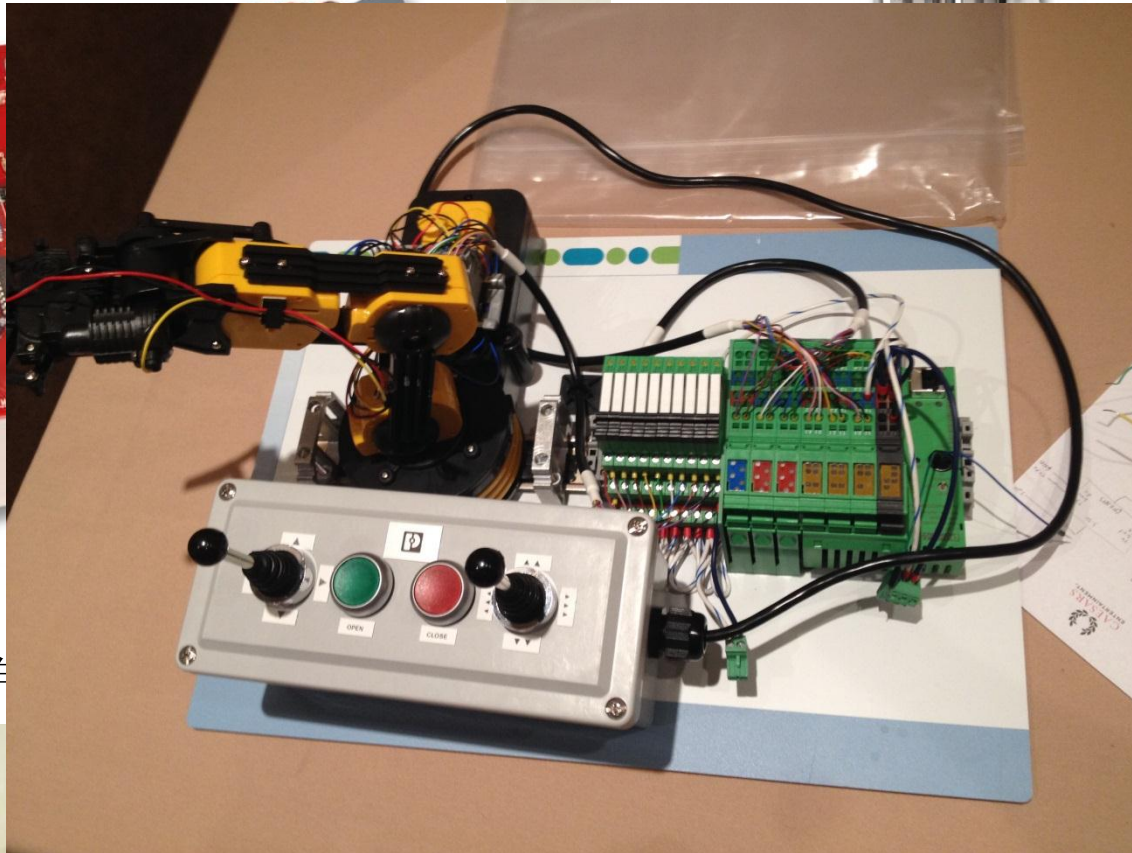


我们的计划

将使用模拟PLC-以
太网连接的ICS环境



控制





当前配置



建立S7-1200与编程设备之间的联系



全集成自动化 (Totally Integrated Automation TIA) 版本V11 SP2



控制器



攻击路径

西门子PLC S7-1200

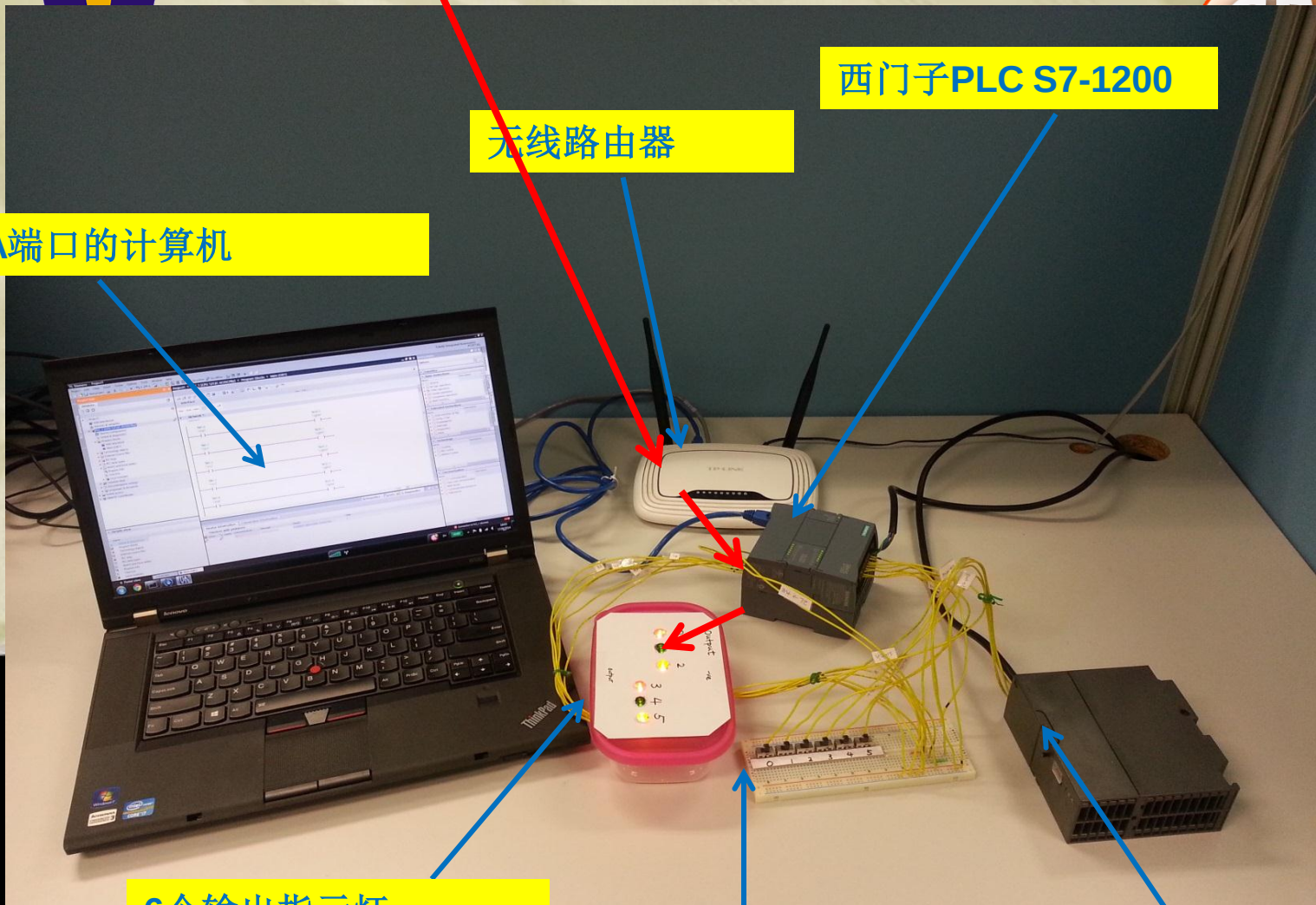
无线路由器

TIA端口的计算机

6个输出指示灯

6个输入开关

24V直流电源供应器





研究工作



Computer Forensics Research Group

- 首先，对上述的ICS模拟环境进行攻击
- 开展了4项研究任务
 - 通过JTAG连接的硬件取证
 - PLC固件逆向工程
 - 网络取证在SCADA网络上的应用
 - SCADA 日志系统的分析



ICS



我们的观点

- 验证了ICS/SCADA系统攻击并不是遥不可及的
- 我们认为，政府出资机构需要采取积极有效的措施，以预防应对关键基础设施攻击
- 如果这些关键基础设施是私人拥有和经营的，应当建立相应的政府机构、实施适当的事件处理过程，并且汇报相应的造成原因

美国工业控制系统网络应
急响应小组 US ICS-CERT





谢谢
Thank You

